

DOCUMENTO 3: PLAN DE RESPUESTA A INCIDENTES (NIST SP 800-61)

PLAN DE RESPUESTA A INCIDENTES DE SEGURIDAD

4Geeks Academy

Basado en NIST SP 800-61 Rev. 2

Versión: 1.0

Fecha de Emisión: 31 de enero de 2026

Próxima Revisión: 31 de julio de 2026

Clasificación: CONFIDENCIAL - USO INTERNO

CONTROL DE VERSIONES

Versión	Fecha	Autor	Cambios Realizados
1.0	31/01/2026	Equipo de Seguridad	Creación inicial del documento

1. PROPÓSITO Y ALCANCE

1.1 Propósito

Este Plan de Respuesta a Incidentes (IRP, por sus siglas en inglés) establece las políticas, procedimientos y recursos necesarios para detectar, responder, mitigar y recuperarse de incidentes de seguridad de la información que afecten a 4Geeks Academy.

Objetivos Principales:

1. Minimizar el impacto de incidentes de seguridad en las operaciones de negocio
2. Proteger los datos sensibles de estudiantes, profesores y personal
3. Cumplir con requisitos legales y regulatorios (RGPD, normativas sectoriales)
4. Preservar evidencias para posibles acciones legales o análisis forense
5. Aprender de cada incidente para mejorar la postura de seguridad

1.2 Alcance

Este plan aplica a:

- **Personas:** Todo el personal, contratistas, proveedores y terceros con acceso a sistemas de 4Geeks Academy
- **Sistemas:** Todos los activos de información (servidores, aplicaciones, bases de datos, redes)
- **Datos:** Información personal, académica, financiera y operativa
- **Ubicaciones:** Todas las instalaciones físicas y servicios cloud de la organización

Exclusiones:

- Incidentes puramente físicos sin componente digital (gestionados por Seguridad Física)
- Incidentes de RRHH sin componente de seguridad de la información
- Desastres naturales (cubiertos por Plan de Continuidad de Negocio)

1.3 Marco Normativo

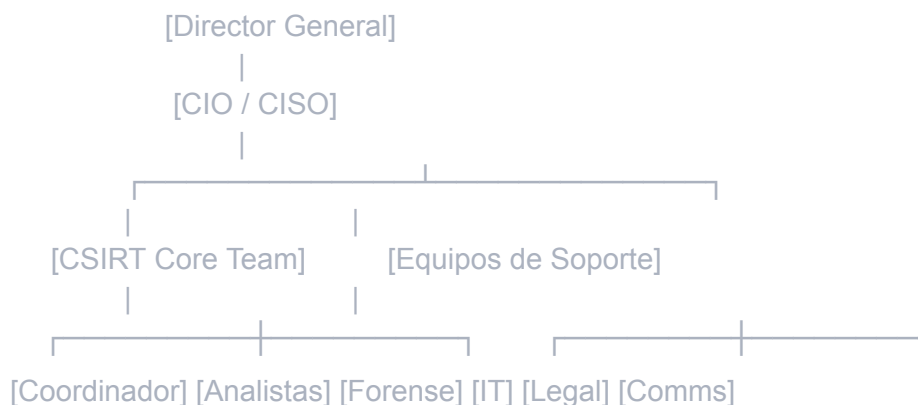
Este plan se basa en:

- **NIST SP 800-61 Rev. 2:** Computer Security Incident Handling Guide
- **ISO/IEC 27035:** Information security incident management
- **RGPD (Reglamento General de Protección de Datos):** Artículos 33 y 34
- **ENS (Esquema Nacional de Seguridad):** Para organizaciones que colaboran con administraciones públicas

2. EQUIPO DE RESPUESTA A INCIDENTES (CSIRT)

2.1 Estructura Organizativa

Modelo: CSIRT Centralizado con Equipos de Soporte Descentralizados



2.2 Roles y Responsabilidades

2.2.1 Coordinador de Respuesta a Incidentes (Incident Response Manager)

Responsabilidades:

- Liderar todas las actividades de respuesta a incidentes
- Coordinar con stakeholders internos y externos
- Tomar decisiones críticas durante incidentes mayores
- Comunicar estado a la Alta Dirección
- Autorizar actividades que impacten en producción
- Gestionar relaciones con autoridades (Policía, AEPD, etc.)

Autoridad:

- Autorizar desconexión de sistemas de red si es necesario
- Requisar recursos de IT para respuesta a incidentes
- Declarar el fin del incidente y retorno a operaciones normales

2.2.2 Analistas de Seguridad (Security Analysts)

Responsabilidades:

- Monitoreo continuo de alertas de seguridad
- Triage inicial de incidentes
- Análisis técnico de eventos de seguridad
- Ejecución de playbooks de respuesta
- Documentación detallada de todas las acciones
- Búsqueda proactiva de amenazas (threat hunting)

Herramientas Asignadas:

- Acceso a SIEM/log aggregation
- Herramientas de análisis forense
- Sistemas de monitoreo de red
- Plataformas de threat intelligence

2.2.3 Especialista Forense (Digital Forensics Specialist)

Responsabilidades:

- Preservación de evidencia digital
- Análisis forense de sistemas comprometidos
- Reconstrucción de cronología de ataques
- Preparación de reportes forenses admisibles legalmente
- Colaboración con fuerzas del orden si es necesario

Capacidades Requeridas:

- Certificaciones: GCFE, EnCE, CHFI o equivalente
- Experiencia con herramientas: EnCase, FTK, Autopsy, Volatility

2.2.4 Equipo de IT / Infraestructura**Responsabilidades:**

- Implementar acciones de contención (ej. aislamiento de sistemas)
- Aplicar parches y configuraciones de seguridad
- Restaurar sistemas desde backups
- Proporcionar acceso técnico al CSIRT
- Ejecutar cambios de infraestructura autorizados

2.2.5 Equipo Legal**Responsabilidades:**

- Asesorar sobre obligaciones legales (RGPD, notificaciones)
- Coordinar con autoridades de protección de datos (AEPD)
- Evaluar necesidad de denuncias penales
- Proteger privilegio attorney-client en investigaciones
- Revisar comunicaciones públicas desde perspectiva legal

2.2.6 Equipo de Comunicaciones**Responsabilidades:**

- Gestionar comunicaciones internas durante incidentes
- Preparar statements públicos si es necesario
- Coordinar con medios de comunicación
- Gestionar comunicación con clientes/estudiantes afectados
- Proteger la reputación de la organización

2.2.7 Enlaces con Terceros**Proveedores Críticos:**

- Hosting Provider: [Nombre] - [Contacto 24/7]
- ISP: [Nombre] - [Contacto]
- Cloud Provider (AWS/Azure/GCP): [Contacto de Soporte]
- Seguridad Gestionada (MSSP): [Si aplica]

Autoridades:

- Policía Nacional / Guardia Civil - Unidad de Delitos Telemáticos
- Agencia Española de Protección de Datos (AEPD): notificaciones@aedp.es
- INCIBE-CERT: [Contacto]

2.3 Niveles de Escalamiento

Nivel	Severidad	Equipo Activado	Autoridad de Decisión
Nivel 0	Informativo	Analista de Seguridad	Analista
Nivel 1	Bajo	Analista + IT	Coordinador IR
Nivel 2	Medio	CSIRT Core Team	Coordinador IR + CIO
Nivel 3	Alto	CSIRT Completo + Legal	CIO + Dirección
Nivel 4	Crítico	Todo CSIRT + CEO + Externos	CEO + Junta Directiva

2.4 Disponibilidad y Turnos

Horario de Oficina (L-V 9:00-18:00):

- Analistas de Seguridad: Disponibles en oficina
- Coordinador IR: Disponible en oficina o remotamente

Fuera de Horario / Fines de Semana:

- **Guardia de Seguridad:** Rotación semanal entre analistas
- **Contacto de Emergencia:** [Número de teléfono 24/7]
- **Tiempo de Respuesta Objetivo:** < 1 hora para incidentes Nivel 3+

Procedimiento de Escalamiento Fuera de Horario:

1. Llamada al móvil del analista de guardia
2. Si no responde en 15 min → Llamar a Coordinador IR
3. Si no responde en 30 min → Llamar a CIO
4. Dejar voicemail y enviar SMS + Email en cada intento

3. POLÍTICAS Y PROCEDIMIENTOS

3.1 Definición de Incidente de Seguridad

Incidente de Seguridad de la Información: Cualquier evento confirmado o sospechado que comprometa la confidencialidad, integridad o disponibilidad de activos de información de 4Geeks Academy.

Ejemplos de Incidentes:

- Acceso no autorizado a sistemas o datos
- Instalación de malware (ransomware, troyanos, spyware)
- Exfiltración de datos sensibles
- Defacement de sitios web
- Ataques de Denegación de Servicio (DoS/DDoS)
- Uso indebido de recursos por usuarios internos
- Phishing exitoso contra empleados
- Pérdida o robo de dispositivos con datos sensibles
- Vulnerabilidades críticas explotadas activamente

No son Incidentes (gestionados por otros procesos):

- Falsos positivos de herramientas de seguridad (tras validación)
- Vulnerabilidades no explotadas (gestionadas por Gestión de Vulnerabilidades)
- Solicitudes de acceso legítimas rechazadas
- Fallos de hardware sin componente de seguridad

3.2 Clasificación de Severidad de Incidentes

Matriz de Clasificación

Criterio	Bajo (1)	Medio (2)	Alto (3)	Crítico (4)
Impacto en Datos	Sin acceso a datos sensibles	Acceso limitado a datos no críticos	Acceso a datos personales	Exfiltración masiva de PII
Sistemas Afectados	1 sistema no crítico	2-5 sistemas	Sistema crítico	Múltiples sistemas críticos
Usuarios Afectados	< 10	10-100	100-1000	> 1000 o todos
Duración de Impacto	< 1 hora	1-4 horas	4-24 horas	> 24 horas
Impacto Financiero	< 1,000€	1,000-10,000€	10,000-100,000 €	> 100,000€

Impacto Reputacional	Ninguno	Menor	Moderado	Severo (medios)
Cumplimiento Legal	Sin implicaciones	Posible notificación interna	Notificación a AEPD probable	Violación RGPD confirmada

Cálculo de Severidad Global:

- Severidad = MÁXIMO(todos los criterios)
- Si ≥ 3 criterios son "Alto" → Automáticamente Crítico

Ejemplos de Clasificación

Nivel 1 - Bajo:

- Single PC infectado con adware, sin acceso a red corporativa
- Intento fallido de phishing detectado por filtro de email
- Escaneo de puertos externo sin explotación exitosa

Nivel 2 - Medio:

- Cuenta de usuario sin privilegios comprometida
- Malware contenido en un único sistema sin propagación
- Explotación de vulnerabilidad media en sistema no crítico

Nivel 3 - Alto:

- Múltiples sistemas infectados con ransomware contenido
- Acceso no autorizado a base de datos de producción
- Defacement de sitio web público
- Exfiltración confirmada de datos personales de < 100 estudiantes

Nivel 4 - Crítico:

- Compromiso de controlador de dominio (Domain Controller)
- Ransomware con cifrado masivo de datos
- Brecha de datos que afecta a > 1,000 estudiantes
- Ataque APT (Advanced Persistent Threat) confirmado
- Servidor de producción comprometido con acceso root

3.3 Objetivos de Tiempo de Respuesta (SLA)

Severidad	Tiempo de Reconocimiento	Inicio de Contención	Resolución Objetivo
Crítico (4)	15 minutos	30 minutos	4 horas
Alto (3)	30 minutos	1 hora	24 horas
Medio (2)	2 horas	4 horas	72 horas
Bajo (1)	8 horas	24 horas	1 semana

Notas:

- Tiempos medidos desde el momento de detección o notificación al CSIRT
- "Resolución" significa contención completa, no necesariamente erradicación total
- Excepciones requieren aprobación del Coordinador IR y documentación

3.4 Canales de Reporte de Incidentes

Para Empleados

Método Primario: Email a security@4geeksacademy.com

- Monitoreado 24/7 por equipo de guardia
- Respuesta automática con número de ticket

Método Secundario: Formulario Web (Intranet)

- <https://intranet.4geeks.com/security-incident-report>
- Campos obligatorios: Nombre, Descripción, Urgencia

Emergencias (Nivel 3+): Teléfono de Guardia

- [+34 XXX XXX XXX]
- Disponible 24/7/365

Información a Proporcionar:

- ¿Qué ocurrió? (Descripción del evento)
- ¿Cuándo ocurrió? (Fecha y hora exactas)
- ¿Quién lo descubrió?
- ¿Qué sistemas están afectados?
- ¿Hay datos sensibles involucrados?
- ¿Se han tomado acciones inmediatas?

Para Sistemas Automatizados

SIEM/IDS Alerts:

- Integración directa con sistema de ticketing
- Clasificación automática según reglas predefinidas
- Escalamiento automático para alertas críticas

Proveedores Externos:

- Email: security@4geeksacademy.com con [EXTERNAL] en asunto
- PGP Key disponible para comunicaciones sensibles

3.5 Políticas de Preservación de Evidencia

Regla de Oro: Cuando hay duda, preservar primero, analizar después.

Procedimientos de Preservación:

1. **No Apagar Sistemas Comprometidos** (salvo ransomware activo)
 - Los datos en RAM se pierden al apagar
 - Capturar memoria volátil primero
2. **Documentar Toda Acción**
 - Quién, qué, cuándo, dónde, por qué, cómo
 - Mantener cadena de custodia estricta
3. **Trabajar con Copias, No con Originales**
 - Crear imágenes forenses bit-a-bit
 - Calcular hashes criptográficos (SHA-256)
 - Nunca modificar evidencia original
4. **Almacenamiento Seguro**
 - Ubicación física: Caja fuerte en oficina central
 - Ubicación digital: Servidor forense aislado de la red
 - Cifrado: AES-256 para todas las imágenes
 - Acceso: Solo personal autorizado del CSIRT

Cadena de Custodia:

Fecha/Hora	Persona	Acción	Hash SHA-256	Firma
DD/MM/YYYY HH:MM	[Nombre]	Creación de imagen	[hash]	[firma]
DD/MM/YYYY HH:MM	[Nombre]	Transferencia a almacenamiento	[hash]	[firma]

Retención de Evidencias:

- **Evidencias de Incidentes Críticos:** 7 años (requisito legal potencial)
- **Evidencias de Incidentes Altos/Medios:** 3 años
- **Evidencias de Incidentes Bajos:** 1 año
- **Logs de Sistema:** 1 año (13 meses para análisis año-a-año)

4. FASES DEL PLAN DE RESPUESTA A INCIDENTES

FASE 1: PREPARACIÓN

4.1.1 Objetivo

Establecer capacidades, herramientas, conocimientos y procedimientos necesarios para responder efectivamente a incidentes antes de que ocurran.

4.1.2 Actividades de Preparación

A. Herramientas y Tecnología

Sistema de Gestión de Incidentes (Ticketing):

- Herramienta: [JIRA Service Desk / ServiceNow / TheHive]
- Funcionalidades requeridas:
 - Clasificación automática
 - Asignación basada en severidad
 - Workflows personalizados
 - Integración con SIEM
 - Métricas y reporting

SIEM (Security Information and Event Management):

- Solución: [Splunk / ELK Stack / QRadar]
- Fuentes de logs integradas:
 - Firewalls (UFW, pfSense)
 - Servidores (Apache, SSH, MySQL)
 - Aplicaciones (WordPress)
 - Sistemas operativos (syslog)
 - Endpoints (EDR)
- Retención: 13 meses online, 7 años en archivo

Análisis Forense:

- Kit de Forensics Jump Bag con:
 - Laptop forense aislado
 - Discos duros portátiles (3TB+)
 - Write blockers hardware
 - Cables y adaptadores variados
 - Documentación y formularios de cadena de custodia
- Software:
 - FTK Imager (imaging)
 - Autopsy (análisis de disco)
 - Volatility (análisis de memoria)
 - Wireshark (análisis de red)
 - KAPE (Kroll Artifact Parser and Extractor)

Sandbox y Análisis de Malware:

- Entorno aislado para detonación de malware
- Herramientas: Cuckoo Sandbox, ANY.RUN, Joe Sandbox
- Análisis estático: PESTudio, IDA Free, Ghidra

Threat Intelligence:

- Feeds integrados:
 - MISP (Malware Information Sharing Platform)
 - AlienVault OTX
 - Abuse.ch (URLhaus, MalwareBazaar)
 - VirusTotal API
- ISAC sectorial: [Si disponible para educación]

Herramientas de Comunicación Segura:

- Signal / Wickr para comunicaciones de crisis
- PGP para emails sensibles
- Videoconferencia cifrada para reuniones de CSIRT

B. Documentación y Playbooks

Playbooks de Respuesta Desarrollados:

1. Compromiso de Servidor Web
2. Ransomware
3. Phishing / Compromiso de Credenciales
4. Exfiltración de Datos
5. DDoS
6. Malware en Endpoints
7. Insider Threat
8. Compromiso de Cloud (AWS/Azure)
9. Ataque a Aplicación Web (SQLi, XSS)
10. Compromiso de Active Directory

Formato de Playbook:

- Indicadores de detección
- Pasos de contención inmediata
- Procedimientos de investigación
- Acciones de erradicación
- Validación de recuperación
- Lecciones aprendidas

C. Formación y Concienciación

Formación del CSIRT:

- Entrenamiento inicial: 40 horas (SANS SEC504 o equivalente)
- Formación continua: 16 horas/año
- Certificaciones objetivo:
 - Coordinador IR: GCIH, CISSP
 - Analistas: GCIA, GCFA
 - Forense: GCFE, CHFI

Ejercicios de Mesa (Tabletop Exercises):

- Frecuencia: Trimestral
- Escenarios rotativos (ransomware, brecha de datos, etc.)
- Duración: 2-4 horas
- Participantes: CSIRT + Alta Dirección

Simulacros Técnicos (Red Team Exercises):

- Frecuencia: Anual
- Proveedor externo: [Pentest as a Service / Red Team]
- Sin previo aviso para el equipo (excepto dirección)

Concienciación General:

- Phishing simulations mensuales
- Newsletter de seguridad mensual
- Formación obligatoria anual para todos los empleados

D. Preparación Legal y de Cumplimiento

Plantillas de Notificación RGPD:

- Notificación a AEPD (Artículo 33) - Plantilla lista
- Notificación a Interesados (Artículo 34) - Plantilla lista
- Plazos claros: 72 horas desde conocimiento del incidente

Acuerdos con Proveedores:

- Cláusulas de respuesta a incidentes en SLAs
- Procesos de notificación definidos
- Acceso de emergencia pre-autorizado

Ciber-Seguro:

- Póliza contratada: [Compañía] - [Número de póliza]
- Cobertura: [Cantidad] para brechas de datos
- Proceso de activación: [Contacto 24/7 de aseguradora]

FASE 2: DETECCIÓN Y ANÁLISIS

4.2.1 Objetivo

Identificar rápidamente incidentes de seguridad, confirmar su veracidad y comprender su alcance y severidad.

4.2.2 Fuentes de Detección

Fuentes Automatizadas (Técnicas):

1. SIEM - Correlación de Eventos

- Reglas de detección configuradas:
 - Múltiples logins fallidos seguidos de éxito
 - Acceso desde geo-localizaciones anómalas
 - Transferencias masivas de datos
 - Creación de usuarios administrativos
 - Cambios en configuraciones críticas
- Alertas enviadas a: security-alerts@4geeksacademy.com

2. **IDS/IPS (Fail2Ban, Snort, Suricata)**
 - Detección de patrones de ataque conocidos
 - Bloqueo automático de IPs maliciosas
 - Alertas para ataques sofisticados que requieren revisión humana
3. **EDR (Endpoint Detection and Response)**
 - Monitoreo de comportamiento en endpoints
 - Detección de malware conocido y desconocido (heurísticas)
 - Aislamiento automático de endpoints comprometidos
4. **WAF (Web Application Firewall)**
 - Protección contra OWASP Top 10
 - Logs de intentos de explotación
 - Integración con SIEM
5. **Monitoreo de Integridad de Archivos (FIM)**
 - Tripwire, OSSEC o similar
 - Alertas ante modificaciones de archivos críticos:
 - /etc/passwd, /etc/shadow
 - Binarios de sistema
 - Archivos de configuración de servicios

Fuentes Humanas:

1. **Empleados**
 - Reportes de comportamiento anómalo
 - Emails de phishing recibidos
 - Dispositivos perdidos o robados
2. **Usuarios (Estudiantes)**
 - Actividad sospechosa en sus cuentas
 - Contenido inapropiado en plataforma
3. **Proveedores**
 - Notificaciones de compromisos en sus sistemas
 - Alertas de threat intelligence
4. **Terceros Externos**
 - Investigadores de seguridad (responsible disclosure)
 - Alertas de CERT/CSIRT nacionales
 - Notificaciones de fuerzas del orden

4.2.3 Procedimiento de Triage Inicial

Tiempo Objetivo: < 30 minutos desde la detección

Paso 1: Verificación (5-10 minutos)

¿Es esto realmente un incidente de seguridad o un falso positivo?

Acciones:

- Revisar logs correlacionados en SIEM
- Verificar con el sistema/usuario afectado
- Consultar threat intelligence (VirusTotal, AbuseIPDB)
- Comprobar si es parte de actividad autorizada (pentesting, mantenimiento)

Resultado:

- Incidente Confirmado → Continuar a Paso 2
- Falso Positivo → Documentar y cerrar ticket

Paso 2: Clasificación Inicial (10-15 minutos)

Aplicar matriz de severidad (Sección 3.2)

Evaluar:

1. Tipo de incidente (malware, acceso no autorizado, DoS, etc.)
2. Sistemas afectados (servidores, aplicaciones, endpoints)
3. Datos involucrados (PII, secretos comerciales, públicos)
4. Impacto actual (servicios caídos, datos exfiltrados)
5. Impacto potencial (propagación, escalada)

Asignar Severidad: 1 (Bajo) | 2 (Medio) | 3 (Alto) | 4 (Crítico)

Paso 3: Asignación y Escalamiento (5 minutos)

Según severidad:

Nivel 1-2 (Bajo/Medio):

- Asignar a analista de guardia
- Notificar a Coordinador IR vía email

Nivel 3 (Alto):

- Asignar a Coordinador IR
- Activar CSIRT Core Team
- Notificar a CIO

Nivel 4 (Crítico):

- Activar CSIRT completo inmediatamente
- Notificar a CIO y CEO
- Convocar reunión de crisis en 30 minutos

Paso 4: Documentación Inicial (5-10 minutos)

Crear ticket en sistema de gestión de incidentes con:

- ID de Incidente: INC-YYYY-NNNN
- Fecha/Hora de detección
- Fuente de detección
- Descripción preliminar
- Severidad asignada
- Personas notificadas
- Acciones inmediatas tomadas (si las hay)

4.2.4 Análisis Profundo

Objetivo: Comprender completamente el incidente (alcance, causa raíz, impacto)

A. Recopilación de Evidencias

Logs del Sistema:

bash

Logs de autenticación

journalctl -u ssh --since "YYYY-MM-DD HH:MM" > auth_logs.txt

grep "Failed|Accepted" /var/log/auth.log > auth_analysis.txt

Logs de aplicación web

tail -n 10000 /var/log/apache2/access.log > web_access.log

tail -n 10000 /var/log/apache2/error.log > web_error.log

Conexiones de red activas

ss -tunap > active_connections.txt

netstat -antp > netstat_output.txt

Procesos en ejecución

ps auxf > running_processes.txt

top -b -n 1 > system_snapshot.txt

Captura de Memoria (si el sistema está comprometido):

bash

Usar LiME (Linux Memory Extractor) o equivalente

sudo insmod lime.ko "path=/mnt/forensics/memory.lime format=raw"

Imagen de Disco Forense:

bash

Solo si se planea apagar el sistema

sudo dd if=/dev/sda of=/mnt/forensics/disk_image.dd bs=4M status=progress

sha256sum /mnt/forensics/disk_image.dd > disk_image.hash

B. Análisis de Indicadores de Compromiso (IoC)

Indicadores Típicos a Buscar:

1. Actividad de Red Sospechosa:

- Conexiones a IPs en listas negras conocidas
- Tráfico hacia países inesperados
- Grandes volúmenes de datos salientes
- Conexiones a puertos no estándar

2. Cambios en el Sistema:

- Nuevos usuarios creados
- Cambios en archivos de configuración
- Archivos ejecutables en ubicaciones temporales
- Tareas cron/scheduled tasks sospechosas

3. Comportamiento Anómalo:

- Procesos con nombres aleatorios
- Alto uso de CPU/memoria sin justificación
- Acceso a archivos/directorios inusuales
- Comandos ejecutados fuera de horario normal

Herramientas de Análisis:

bash

Búsqueda de archivos modificados recientemente

```
find / -type f -mtime -1 2>/dev/null
```

Archivos SUID sospechosos

```
find / -perm -4000 -type f 2>/dev/null > suid_files.txt
```

Revisión de crontabs

```
for user in $(cat /etc/passwd | cut -d: -f1); do
```

```
    echo "=== $user ==="
```

```
    crontab -u $user -l 2>/dev/null
```

```
done
```

Análisis de persistencia

```
cat /etc/rc.local
```

```
ls -la /etc/systemd/system/
```

```
...
```

****C. Análisis de Causa Raíz****

****Preguntas Clave:****

1. ¿Cómo ganó el atacante el acceso inicial? (Vector de ataque)
2. ¿Qué vulnerabilidad fue explotada?
3. ¿Cuándo comenzó el compromiso? (Timeline)
4. ¿Qué privilegios obtuvo el atacante?
5. ¿Hubo movimiento lateral a otros sistemas?
6. ¿Qué datos fueron accedidos o exfiltrados?
7. ¿Existen backdoors o mecanismos de persistencia?

****Metodología de Análisis:****

- Construir timeline cronológica de eventos
- Correlacionar eventos en múltiples fuentes de logs
- Identificar TTP (Tactics, Techniques, Procedures) del atacante
- Mapear a MITRE ATT&CK Framework

****D. Evaluación de Impacto****

****Datos a Determinar:****

Pregunta	Cómo Determinarlo	Importancia
¿Qué datos fueron accedidos?	Logs de acceso a BD, archivos accedidos	Crítico para RGPD
¿Cuántos registros de usuarios?	Consultas a BD, análisis de logs	Obligatorio para notificación
¿Datos sensibles exfiltrados?	Análisis de tráfico de red, logs de FTP/HTTP	Determinante de severidad
¿Sistemas aún comprometidos?	Escaneo de IoCs, análisis de persistencia	Necesario para contención
¿Impacto en operaciones?	Consulta a IT, usuarios	Importante para negocio

FASE 3: CONTENCIÓN, ERRADICACIÓN Y RECUPERACIÓN

4.3.1 Objetivo

Detener la propagación del incidente, eliminar la amenaza del entorno y restaurar los sistemas a un estado operativo seguro.

4.3.2 Estrategias de Contención

****A. Contención de Corto Plazo (Inmediata)****

****Objetivo:**** Detener el daño activo mientras se preserva evidencia

****Técnicas según Tipo de Incidente:****

****1. Malware/Ransomware Activo:****

...

Acciones (en orden):

- 1. AISLAR - No apagar (RAM se perdería)**
 - Desconectar cable de red físicamente
 - O deshabilitar adaptador de red: `ip link set eth0 down``
- 2. BLOQUEAR propagación**
 - Identificar IPs/dominios C2 (Command & Control)
 - Bloquear en firewall perimetral
- 3. CAPTURAR memoria**
 - Antes de cualquier otra acción invasiva
- 4. SOLO ENTONCES considerar apagar si es necesario**

...

****2. Acceso No Autorizado Activo:****

...

Acciones:

1. **TERMINAR sesión del atacante**
 - Identificar sesión SSH/RDP: ``who` o `w``
 - Kill process: ``kill -9 [PID]``
 2. **BLOQUEAR IP origen**
 - ``ufw deny from [IP_ATACANTE]``
 - Añadir regla permanente en firewall perimetral
 3. **ROTAR credenciales comprometidas**
 - Cambiar passwords de usuarios afectados
 - Revocar claves SSH
 - Invalidar tokens de sesión
 4. **AUMENTAR logging**
 - Habilitar logging de nivel DEBUG temporalmente
 - Monitorear por nuevos intentos
- ...

****3. Exfiltración de Datos en Curso:****

...

Acciones:

1. **IDENTIFICAR flujo de datos**
 - ``iftop``, ``nethogs`` para ver conexiones activas
 - Identificar proceso: ``lsof -i -P -n``
 2. **BLOQUEAR conexión saliente**
 - Kill proceso: ``kill -9 [PID]``
 - Bloquear IP destino en firewall
 3. **CAPTURAR tráfico para análisis**
 - ``tcpdump -i eth0 -w exfil_capture.pcap host [IP]``
 4. **EVALUAR qué se exfiltró**
 - Análisis del pcap capturado
 - Revisión de logs de aplicación
- ...

****4. DDoS en Curso:****

...

Acciones:

1. **ACTIVAR protección DDoS**
 - Si cloud: Cloudflare, AWS Shield
 - Si on-prem: Rate limiting agresivo

2. CONTACTAR ISP/proveedor

- Activar mitigación upstream

3. MANTENER servicios críticos

- Priorizar tráfico legítimo
- Reducir funcionalidades no esenciales temporalmente

...

B. Contención de Largo Plazo (Sostenible)

****Objetivo:**** Mantener el incidente contenido mientras se planifica erradicación completa

****Acciones Generales:****

1. ****Segmentación de Red:****

- Mover sistemas afectados a VLAN de cuarentena
- Permitir solo tráfico esencial (actualizaciones, monitoreo)

2. ****Refuerzo de Monitoreo:****

- Desplegar honeypots en red afectada
- Aumentar frecuencia de escaneo de vulnerabilidades
- Monitoreo 24/7 hasta resolución completa

3. ****Parches de Emergencia:****

- Aplicar parches críticos en sistemas no afectados
- Prevenir propagación horizontal

4. ****Comunicación Controlada:****

- Informar a usuarios afectados (si es necesario)
- Sin revelar detalles técnicos que ayuden al atacante

4.3.3 Erradicación

****Objetivo:**** Eliminar completamente la amenaza del entorno

****Procedimiento General:****

****Paso 1: Identificar Todos los Sistemas Afectados****

...

- Escanear red completa por IoCs identificados
- Revisar logs centralizados por patrones similares
- No asumir que solo un sistema está comprometido

Paso 2: Eliminar Malware y Backdoors

bash

Para malware conocido

`sudo rkhunter --check`

`sudo chkrootkit`

Para backdoors en servicios

`systemctl list-units --type=service --all | grep -v "loaded active"`

`find /etc/systemd/system -type f -newer [fecha_incidente]`

Para cuentas de usuario maliciosas

`awk -F: '$3 >= 1000 {print $1}' /etc/passwd`

Revisar y eliminar cuentas no autorizadas

`sudo userdel -r [usuario_malicioso]`

...

****Paso 3: Cerrar Vectores de Explotación****

...

- Parchear vulnerabilidades explotadas
- Cambiar TODAS las credenciales potencialmente comprometidas
- Eliminar o deshabilitar puntos de entrada (ej. servicios innecesarios)
- Corregir configuraciones inseguras

...

****Paso 4: Fortalecer Controles****

...

- Implementar reglas de firewall adicionales
- Configurar alertas específicas para detectar reinfección
- Actualizar signatures de antivirus/IDS

Decisión Crítica: ¿Limpiar o Reconstruir?

Criterio	Limpiar	Reconstruir
Severidad	Bajo-Medio	Alto-Crítico
Confianza en limpieza	Alta	Baja o incierta
Tiempo de recuperación	Limpiar es más rápido	Reconstruir puede ser más seguro
Sistemas afectados	1-2	3+ o sistemas críticos
Tipo de malware	Malware conocido	Rootkit, APT, desconocido
Backups disponibles	No/Antiguos	Sí, recientes y limpios

Recomendación General: En caso de duda, reconstruir desde cero es la opción más segura.

4.3.4 Recuperación

Objetivo: Restaurar sistemas a operación normal completa y validar que están limpios

A. Restauración desde Backups (Si se reconstruye)

Procedimiento:

1. Validar Integridad de Backups:

```
bash
# Verificar que el backup es anterior al compromiso
ls -lh /backup/wordpress_*

# Verificar hash del backup
sha256sum /backup/wordpress_20241001.tar.gz
# Comparar con hash almacenado

# Escanear backup por malware ANTES de restaurar
clamscan -r /backup/restored_files/
```

2. Preparar Sistema Limpio:

```
bash
# Re-instalar OS desde ISO oficial
# Aplicar TODOS los parches de seguridad
sudo apt update && sudo apt upgrade -y

# Configurar según baseline de seguridad
# (Aplicar playbook de hardening)
```

3. Restaurar Datos:

```
bash
# Restaurar archivos
sudo tar -xzf /backup/wordpress_20241001.tar.gz -C /var/www/html

# Restaurar base de datos
mysql -u root -p wordpress < /backup/wordpress_db_20241001.sql

# Verificar permisos
sudo chown -R www-data:www-data /var/www/html
sudo chmod -R 755 /var/www/html
```

4. Reconfigurar Seguridad:

bash

Generar NUEVAS credenciales (no restaurar las antiguas)

```
mysql> ALTER USER 'wordpressserver'@'localhost' IDENTIFIED BY  
'[NEW_SECURE_PASSWORD]';
```

Regenerar WordPress salt keys

(Desde <https://api.wordpress.org/secret-key/1.1/salt/>)

Aplicar configuraciones de seguridad mejoradas

(Deshabilitar XML-RPC, directory listing, etc.)

```

**\*\*B. Validación de Recuperación\*\***

**\*\*Checklist de Validación:\*\***

- [ ] Sistema arranca correctamente
- [ ] Todos los servicios necesarios están activos
- [ ] No hay procesos sospechosos en ejecución
- [ ] Conexiones de red son solo las esperadas
- [ ] Archivos de configuración están correctos
- [ ] Escaneo de vulnerabilidades no encuentra problemas críticos
- [ ] Escaneo antivirus/malware da negativo
- [ ] Logs no muestran actividad anómala
- [ ] Usuarios pueden acceder y usar el sistema normalmente
- [ ] Funcionalidades críticas validadas (login, registro, etc.)

**\*\*Período de Observación:\*\***

- Mínimo 72 horas de monitoreo intensivo
- Escalamiento de logging a nivel DEBUG
- Revisión manual de logs cada 8 horas
- Escaneos de seguridad cada 24 horas

**\*\*C. Retorno a Operaciones Normales\*\***

**\*\*Criterios para Declarar "Incidente Resuelto":\*\***

1. Todos los sistemas afectados limpios o reconstruidos
2. Sin señales de actividad maliciosa en 72 horas
3. Validaciones técnicas completadas exitosamente
4. Usuarios no reportan problemas relacionados
5. Documentación del incidente completa
6. Lecciones aprendidas capturadas
7. Medidas preventivas implementadas
8. Aprobación del Coordinador IR y CIO

**\*\*Comunicación de Cierre:\*\***

- Email interno al personal relevante
- Actualización en sistema de ticketing
- Notificación a stakeholders externos si aplica
- Programar sesión de "lessons learned"

---

### ### FASE 4: ACTIVIDADES POST-INCIDENTE

#### #### 4.4.1 Objetivo

Aprender del incidente para mejorar capacidades de seguridad y prevenir recurrencias.

#### #### 4.4.2 Reunión de Lecciones Aprendidas (Post-Mortem)

**\*\*Cuándo:\*\*** Dentro de 1 semana tras resolver el incidente (para incidentes Nivel 3-4)

**\*\*Participantes:\*\***

- CSIRT completo
- Personal de IT involucrado
- Stakeholders de negocio afectados
- Management (según severidad)

**\*\*Agenda (Duración: 1-2 horas):\*\***

1. **\*\*Cronología del Incidente (20 min)\*\***

- Presentación de timeline completa
- Decisiones clave tomadas y su impacto

2. **\*\*Análisis de Causa Raíz (30 min)\*\***

- ¿Qué falló?
- ¿Por qué falló?
- ¿Cómo se pudo haber prevenido?

3. **\*\*Evaluación de la Respuesta (20 min)\*\***

- ¿Qué funcionó bien?
- ¿Qué no funcionó?
- ¿Cumplimos nuestros SLAs?
- ¿Comunicaciones fueron efectivas?

4. **\*\*Mejoras Identificadas (30 min)\*\***

- Técnicas (herramientas, procesos)
- Organizativas (roles, responsabilidades)
- Formación necesaria

5. **\*\*Plan de Acción (20 min)\*\***

- Asignar responsables y fechas límite
- Priorizar mejoras (crítico, alto, medio)



**\*\*Output:\*\*** Informe de Lecciones Aprendidas (3-5 páginas)

#### #### 4.4.3 Métricas y KPIs

**\*\*Métricas por Incidente:\*\***

- Tiempo de Detección (desde el inicio hasta que lo supimos)
- Tiempo de Reconocimiento (desde detección hasta triaje)
- Tiempo de Contención (desde triaje hasta contener)
- Tiempo Total de Resolución
- Número de sistemas afectados
- Impacto financiero estimado
- Datos comprometidos (cantidad de registros)

**\*\*KPIs Agregados (Mensuales/Trimestrales):\*\***

| KPI | Objetivo | Medición |

|----|-----|-----|

| MTTD (Mean Time To Detect) | < 1 hora | Promedio mensual |

| MTTR (Mean Time To Respond) | < 4 horas | Promedio mensual |

| % de Incidentes Nivel 3+ | < 5% del total | Mensual |

| Tasa de Falsos Positivos | < 20% | Mensual |

| Cumplimiento de SLA | > 95% | Trimestral |

| Satisfacción del Cliente Interno | > 4/5 | Trimestral (encuesta) |

**\*\*Dashboard de Seguridad:\*\***

- Panel ejecutivo en tiempo real mostrando métricas clave
- Actualizado diariamente
- Accesible para CIO, CISO y Alta Dirección

#### #### 4.4.4 Mejora Continua

**\*\*Proceso de Implementación de Mejoras:\*\***

##### 1. **\*\*Captura de Mejoras:\*\***

- Durante respuesta: Documentar problemas encontrados
- Post-mortem: Identificar formalmente mejoras necesarias
- Input continuo de equipo CSIRT

##### 2. **\*\*Priorización:\*\***

- Matriz de Impacto vs Esfuerzo
- Prioridades:
  - P0: Crítico - Implementar inmediatamente
  - P1: Alto - Implementar en 1 mes
  - P2: Medio - Implementar en 3 meses
  - P3: Bajo - Implementar cuando haya recursos

### 3. **\*\*Asignación de Responsabilidades:\*\***

- Dueño de la mejora (quien garantiza que se haga)
- Ejecutor (quien hace el trabajo técnico)
- Fecha compromiso

### 4. **\*\*Seguimiento:\*\***

- Revisión semanal del backlog de mejoras en reunión de CSIRT
- Reporte mensual a CIO sobre progreso
- Cierre formal con validación de implementación

### **\*\*Actualización de Documentación:\*\***

- Playbooks actualizados tras cada incidente significativo
- Procedimientos operativos mejorados según lecciones aprendidas
- Este IRP revisado al menos anualmente

## **#### 4.4.5 Compartir Conocimiento**

### **\*\*Interno:\*\***

- Newsletter de seguridad mensual con incidentes anonimizados
- Sesiones de formación basadas en incidentes reales
- Actualización de formación de onboarding

### **\*\*Externo (si aplica):\*\***

- Compartir IoCs con comunidad (MISP, ISACs)
- Contribuir a threat intelligence feeds
- Participar en grupos de trabajo sectoriales
- Publicar blog posts técnicos (sin información sensible)

---

## ## 5. MATRIZ DE CLASIFICACIÓN DE INCIDENTES

### ### 5.1 Tabla de Referencia Rápida

| Tipo de Incidente | Ejemplos | Severidad Típica | Playbook Asociado |  
|-----|-----|-----|-----|  
| **\*\*Compromiso de Servidor\*\*** | Root access no autorizado, backdoor instalado | Alto-Crítico | PB-01 |  
| **\*\*Malware\*\*** | Virus, troyanos, spyware | Bajo-Medio | PB-06 |  
| **\*\*Ransomware\*\*** | Cifrado de archivos, demanda de rescate | Crítico | PB-02 |  
| **\*\*Phishing\*\*** | Email malicioso recibido/clickeado | Bajo-Medio | PB-03 |  
| **\*\*Compromiso de Credenciales\*\*** | Passwords filtrados, sesión hijacking | Medio-Alto | PB-03 |  
| **\*\*Exfiltración de Datos\*\*** | Descarga masiva, transferencia no autorizada | Alto-Crítico | PB-04 |  
| **\*\*DDoS\*\*** | Denegación de servicio volumétrica | Medio-Alto | PB-05 |  
| **\*\*Defacement\*\*** | Modificación de sitio web público | Medio | PB-01 |  
| **\*\*Insider Threat\*\*** | Abuso de acceso por empleado | Medio-Alto | PB-07 |  
| **\*\*Ataque a Aplicación Web\*\*** | SQLi, XSS, RCE | Alto | PB-09 |  
| **\*\*Cloud Compromise\*\*** | Acceso no autorizado a AWS/Azure | Alto-Crítico | PB-08 |  
| **\*\*Vulnerabilidad Crítica\*\*** | 0-day publicado, explotación activa | Alto | [Gestión Vulnerabilidades] |  
| **\*\*Pérdida/Robo de Dispositivo\*\*** | Laptop robado con datos | Medio-Alto | PB-10 |

### ### 5.2 Matriz de Escalamiento

|                      | Bajo (1)     | Medio (2)                | Alto (3)                    | Crítico (4)                       |
|----------------------|--------------|--------------------------|-----------------------------|-----------------------------------|
| Detección            | Analista     | Analista + Notif. Coord. | Coordinador IR + CSIRT Core | Coordinador IR + CSIRT Completo   |
| Decisión             | Analista     | Coordinador IR           | Coordinador + CIO           | CEO + Directiva                   |
| Comms                | No necesario | Email interno            | Email + Reunión             | Statement Público + AEPD + INCIBE |
| Legal                | No           | Consulta                 | Involucrar activo           | Involucrar total                  |
| Tiempo de resolución | 1 semana     | 72 horas                 | 24 horas                    | 4 horas                           |

## 6. PLANTILLAS DE COMUNICACIÓN

### 6.1 Notificación Interna - Incidente Alto/Crítico

**Asunto:** [INCIDENTE DE SEGURIDAD - NIVEL X] - [Título Breve]

**Para:** equipo-it@4geeks.com, direccion@4geeks.com

**De:** security@4geeksacademy.com

**Prioridad:** Alta

---

#### INFORMACIÓN DEL INCIDENTE

- **ID de Incidente:** INC-2026-0001
- **Severidad:** [Alto / Crítico]
- **Estado:** [En Curso / Contenido / Resuelto]
- **Fecha/Hora Detección:** DD/MM/YYYY HH:MM

#### RESUMEN EJECUTIVO

[2-3 párrafos describiendo qué ocurrió, sistemas afectados, impacto preliminar]

#### SISTEMAS AFECTADOS

- [Lista de sistemas, servicios o aplicaciones]

#### ACCIONES TOMADAS

- [Lista de acciones de contención y respuesta ejecutadas]

#### ACCIONES PENDIENTES

- [Próximos pasos planificados]

#### IMPACTO EN USUARIOS

- [Si los usuarios experimentarán degradación de servicio, etc.]

#### PRÓXIMA ACTUALIZACIÓN

Próximo update programado para: [Fecha/Hora]

Frecuencia de updates: Cada [X horas] mientras el incidente esté activo

#### CONTACTO

Para preguntas o información adicional:

[Coordinador IR - Nombre - Email - Teléfono]

## 6.2 Notificación a AEPD (Artículo 33 RGPD)

[Enviar vía Sede Electrónica AEPD dentro de 72 horas]

### DATOS DEL RESPONSABLE DEL TRATAMIENTO

- Razón Social: 4Geeks Academy S.L.
- NIF: [XXXXXXXXXX]
- Dirección: [Dirección completa]
- Persona de Contacto: [Nombre - DPO o Representante Legal]
- Email: [dpo@4geeksacademy.com]
- Teléfono: [+34 XXX XXX XXX]

### DESCRIPCIÓN DE LA VIOLACIÓN

- **Fecha de Ocurrencia:** [DD/MM/YYYY]
- **Fecha de Conocimiento:** [DD/MM/YYYY]
- **Tipo de Violación:** [Confidencialidad / Integridad / Disponibilidad]

### NATURALEZA DE LA VIOLACIÓN:

[Descripción detallada de qué ocurrió, incluyendo:

- Cómo se produjo la violación
- Qué datos personales se vieron afectados
- Número aproximado de interesados afectados
- Número aproximado de registros de datos afectados]

### CATEGORÍAS DE DATOS AFECTADOS:

- Datos identificativos (nombre, DNI, dirección)
- Datos de contacto (email, teléfono)
- Datos académicos (notas, expediente)
- Datos financieros (pagos, facturación)
- Categorías especiales (art. 9 RGPD): [Si aplica]

### CONSECUENCIAS PROBABLES

[Evaluación del impacto potencial en los interesados, ej.:

- Riesgo de suplantación de identidad
- Posible phishing dirigido
- Daño reputacional
- Etc.]

### MEDIDAS ADOPTADAS

[Descripción de medidas de contención, mitigación y remediación implementadas]

### COMUNICACIÓN A LOS INTERESADOS (Art. 34)

- Sí, se ha comunicado (adjuntar modelo de comunicación)
  - No, porque: [Justificación según Art. 34.3]
- 

### **6.3 Comunicación a Interesados Afectados (Artículo 34 RGPD)**

**Asunto:** Notificación Importante sobre Seguridad de tus Datos - 4Geeks Academy

Estimado/a [Nombre],

Te escribimos para informarte sobre un incidente de seguridad que ha afectado a datos personales que mantenemos en nuestros sistemas.

#### **¿Qué ha ocurrido?**

[Explicación en lenguaje sencillo del incidente]

#### **¿Qué datos se han visto afectados?**

Según nuestra investigación, los datos tuyos que podrían haberse visto afectados incluyen:

- [Lista específica de tipos de datos]

#### **¿Qué estamos haciendo?**

Hemos tomado las siguientes medidas inmediatas:

- [Lista de acciones de seguridad implementadas]

#### **¿Qué puedes hacer tú?**

Te recomendamos tomar las siguientes precauciones:

1. Cambiar tu contraseña de acceso a nuestra plataforma (si aún no lo has hecho)
2. Estar atento a posibles emails de phishing que puedan usar esta información
3. Monitorear tus cuentas bancarias si compartiste información de pago (si aplica)
4. [Otras recomendaciones específicas]

#### **Información de Contacto**

Si tienes preguntas o preocupaciones, puedes contactarnos en:

- Email: [dpo@4geeksacademy.com](mailto:dpo@4geeksacademy.com)
- Teléfono: [XXX XXX XXX]
- Horario de Atención: Lunes a Viernes, 9:00-18:00

También puedes contactar directamente con la Agencia Española de Protección de Datos (AEPD):

- Web: <https://www.aepd.es>

- Teléfono: 901 100 099

Lamentamos sinceramente este incidente y te aseguramos que estamos haciendo todo lo posible para proteger tu información y prevenir que esto vuelva a ocurrir.

Atentamente,

[Nombre]

[Cargo - Representante Legal / DPO]

4Geeks Academy

## 7. PROCEDIMIENTOS ESPECÍFICOS POR TIPO DE INCIDENTE

### 7.1 PLAYBOOK PB-01: Compromiso de Servidor Web

#### TRIGGERS DE ACTIVACIÓN:

- Acceso SSH/RDP no autorizado detectado
- Modificaciones en archivos de sistema o aplicación web
- Backdoor o webshell descubierto
- Evidencia de acceso a nivel root/administrador

**SEVERIDAD TÍPICA:** Alto a Crítico

#### FASE DE CONTENCIÓN

##### Acciones Inmediatas (5-15 minutos):

1. **Aislar el Servidor** (Si es posible sin perder evidencia)

bash

*# Opción 1: Desconectar de red (preserva RAM)*

```
sudo ip link set eth0 down
```

*# Opción 2: Reglas de firewall restrictivas*

```
sudo ufw default deny incoming
```

```
sudo ufw default deny outgoing
```

```
sudo ufw allow from [IP_ADMIN] to any port 22
```

2. **Capturar Estado Actual**

bash

*# Memoria (si LiME está disponible)*

```
sudo insmod lime.ko "path=/tmp/memory.lime format=raw"
```

*# Conexiones activas*

```
sudo ss -tunap > /tmp/connections_$(date +%s).txt
sudo netstat -antp >> /tmp/connections_$(date +%s).txt
```

*# Procesos*

```
ps auxf > /tmp/processes_$(date +%s).txt
```

*# Usuarios logueados*

```
who > /tmp/users_$(date +%s).txt
```

```
w >> /tmp/users_$(date +%s).txt
```

### 3. Identificar Sesiones Activas del Atacante

bash

*# Ver quién está logueado*

```
who
```

*# Si hay sesión sospechosa*

```
sudo pkill -9 -t pts/X # donde X es el terminal del atacante
```

### 4. Bloquear IP del Atacante

bash

*# En firewall local*

```
sudo ufw deny from [IP_ATACANTE]
```

*# En firewall perimetral (solicitar a IT)*

*# Añadir regla permanente de bloqueo*

## FASE DE INVESTIGACIÓN

### Análisis de Logs:

bash

*# Logs de autenticación SSH*

```
sudo journalctl -u ssh --since "YYYY-MM-DD" | grep -E "Accepted|Failed"
```

```
sudo grep "Accepted|Failed" /var/log/auth.log
```

*# Comandos ejecutados por el atacante (si auditd está habilitado)*

```
sudo ausearch -ts recent -k command_execution
```

*# Archivos modificados recientemente*

```
sudo find / -type f -mtime -1 -ls 2>/dev/null | grep -v "/proc|/sys"
```

*# Conexiones de red en las últimas 24h (si guardadas)*

```
sudo grep -r "$(date -d '1 day ago' +%Y-%m-%d)" /var/log/
```



## Buscar Backdoors y Webshells:

bash

*# Webshells en directorio web*

```
sudo find /var/www -type f -name "*.php" | xargs grep -l
"eval(\|base64_decode\|system(\|exec(\|shell_exec"
```

*# Archivos PHP sospechosos por fecha*

```
sudo find /var/www -type f -name "*.php" -mtime -7 -ls
```

*# Tareas cron maliciosas*

```
sudo crontab -l
```

```
for user in $(cut -f1 -d: /etc/passwd); do
```

```
 echo "=== Crontab for $user ===";
```

```
 sudo crontab -u $user -l 2>/dev/null;
```

```
done
```

*# Servicios systemd sospechosos*

```
sudo systemctl list-units --type=service --all | grep -v "loaded active"
```

```
sudo find /etc/systemd/system -type f -mtime -7
```

## Determinar Método de Acceso Inicial:

Preguntas clave:

- ¿Credenciales comprometidas? → Revisar logs de autenticación
- ¿Vulnerabilidad explotada? → Revisar logs de aplicación web, errores
- ¿Backdoor pre-existente? → Buscar indicios de compromiso anterior

## FASE DE ERRADICACIÓN

### Opción A: Reconstrucción Completa (RECOMENDADO para incidentes Nivel 3-4)

1. Provisionar nuevo servidor limpio
2. Aplicar configuración hardened
3. Restaurar datos desde backup verificado como limpio
4. Migrar tráfico al nuevo servidor
5. Destruir servidor comprometido tras análisis forense

### Opción B: Limpieza In-Situ (Solo para Nivel 1-2 con alta confianza)

1. Eliminar backdoors identificados
2. Eliminar usuarios maliciosos
3. Rotar TODAS las credenciales
4. Aplicar parches de seguridad
5. Reconfigurar servicios según baseline seguro

## FASE DE RECUPERACIÓN

1. Validar que el sistema está limpio:

bash

```
Escaneo de rootkits
sudo rkhunter --check
sudo chkrootkit
```

```
Escaneo de malware
sudo clamscan -r /
```

```
Validación de integridad de sistema
sudo debsums -c # En Debian/Ubuntu
```

2. Monitoreo intensivo por 72 horas
3. Validación funcional del servicio
4. Retorno gradual a producción

## LECCIONES APRENDIDAS

### Preguntas para Post-Mortem:

- ¿Cómo obtuvieron acceso inicial?
- ¿Qué vulnerabilidad/debilidad explotaron?
- ¿Por qué nuestras defensas no lo detectaron antes?
- ¿Qué controles adicionales habrían prevenido esto?
- ¿Nuestros backups fueron efectivos?

## 7.2 PLAYBOOK PB-02: Ransomware

### TRIGGERS:

- Archivos cifrados con extensiones anómalas (.encrypted, .locked, etc.)
- Notas de rescate (README.txt, HOW\_TO\_DECRYPT.html)
- Alertas de antivirus/EDR
- Usuarios reportando pérdida de acceso a archivos

**SEVERIDAD:** Crítico

**CONTENCIÓN INMEDIATA (CRÍTICA - MINUTOS IMPORTAN)**

**PASO 1: AISLAR INMEDIATAMENTE (< 2 minutos)**

bash

```
EN EL SISTEMA INFECTADO:
Si es Linux:
sudo ip link set eth0 down
```

*# Si es Windows:*

Disable-NetAdapter -Name "Ethernet"

*# O FÍSICAMENTE desconectar cable de red*

## **PASO 2: Identificar Alcance (< 5 minutos)**

bash

*# Listar archivos cifrados*

find / -name "\*.encrypted" -o -name "\*.locked" 2>/dev/null | head -20

*# Buscar nota de rescate*

find / -name "\*README\*" -o -name "\*DECRYPT\*" -o -name "\*RANSOM\*" 2>/dev/null

*# Ver procesos sospechosos*

ps auxf | grep -v "grep" | grep -E "crypt|lock|ransom"

## **PASO 3: Contener Propagación**

bash

*# Deshabilitar SMB (si está activo - vector común)*

sudo systemctl stop smbd

sudo systemctl disable smbd

*# Bloquear IPs de C2 (si se identifican)*

sudo ufw deny out to [IP\_C2]

*# Desconectar TODOS los sistemas de backup de la red*

*# (Para evitar que también se cifren)*

## **PASO 4: Notificación de Crisis**

- **LLAMAR** (no email) al Coordinador IR inmediatamente
- **LLAMAR** al CIO
- **Activar** CSIRT completo en modo de crisis
- **NO PAGAR** el rescate sin autorización explícita de CEO

## **INVESTIGACIÓN**

### **Identificar Variante de Ransomware:**

bash

*# Obtener muestra del ejecutable (si está aún en ejecución)*

sudo cp /proc/[PID]/exe /tmp/ransomware\_sample

*# O encontrar el binario*

find / -type f -executable -mtime -1 2>/dev/null

```
Calcular hash
sha256sum /tmp/ransomware_sample
```

```
Buscar en bases de datos:
- VirusTotal
- Hybrid Analysis
- ID Ransomware (https://id-ransomware.malwarehunterteam.com/)
```

### Buscar Claves de Descifrado:

Algunos ransomware dejan claves en memoria o archivos temporales:

```
bash
Strings en memoria (si se capturó)
strings memory.lime | grep -i "key\|pass\|decrypt"
```

```
Archivos temporales recientes
find /tmp -type f -mtime -1
find /var/tmp -type f -mtime -1
```

### DECISIÓN: ¿Recuperar o Reconstruir?

#### Factores a Considerar:

| Factor                    | Pagar Rescate  | Restaurar Backup   | Reconstruir        |
|---------------------------|----------------|--------------------|--------------------|
| Backups Disponibles       | No necesario   | Sí                 | Sí, pero más lento |
| Backups Comprometidos     | Considerar     | NO viable          | Única opción       |
| Datos Críticos sin Backup | Última opción  | NO viable          | Pérdida de datos   |
| Presión de Tiempo         | Rápido (horas) | Medio (horas-días) | Lento (días)       |
| Costo                     | 10k-1M€+       | Bajo               | Medio              |
| Garantía                  | NINGUNA        | Alta               | Alta               |
| Ético/Legal               | Problemático   | Sin problemas      | Sin problemas      |

**Recomendación General:** NUNCA pagar rescate como primera opción. Exhaust todas las demás alternativas primero.

#### Si Excepcionalmente se Decide Pagar:

1. Requiere aprobación de CEO + Junta Directiva
2. Involucrar FBI/Policía Nacional (pueden tener claves)
3. Involucrar ciber-seguro (puede cubrir parte del costo)
4. Documentar todo (puede ser evidencia legal)
5. Usar intermediario especializado en negociación de ransomware
6. IMPORTANTE: No hay garantía de que te den la clave, o que funcione

## **ERRADICACIÓN Y RECUPERACIÓN**

### **Si HAY Claves de Descifrado o Herramienta:**

bash

*# Buscar herramienta de descifrado oficial*

*# Ej: No More Ransom Project (<https://www.nomoreransom.org/>)*

*# Validar herramienta (verificar hash con fuente oficial)*

*# Probar en ARCHIVOS DE PRUEBA primero*

*# NO descifrar todo de inmediato sin validar*

*# Si funciona, proceder con descifrado completo*

### **Si NO HAY Recuperación Posible:**

#### **1. Restaurar desde Backup:**

bash

*# Validar que backup no está infectado*

*clamscan -r /backup/path*

*# Restaurar en sistema LIMPIO*

*# (Nunca restaurar sobre sistema infectado)*

#### **2. Reconstruir Sistemas:**

- Re-instalar OS desde ISO limpio
- Reconfigurar según baseline
- Restaurar solo datos necesarios y verificados

## **POST-INCIDENTE**

### **Obligatorio:**

- Denuncia a Policía Nacional / Guardia Civil
- Notificación a AEPD (si datos personales afectados)
- Análisis forense completo
- Actualización de Cyber-Seguro
- Mejoras de prevención (backup offline, segmentación, EDR)

## 7.3 PLAYBOOK PB-03: Compromiso de Credenciales / Phishing

### TRIGGERS:

- Usuario reporta email de phishing clickeado
- Alerta de login desde geo-localización anómala
- Múltiples logins fallidos seguidos de éxito
- Actividad anómala en cuenta de usuario

**SEVERIDAD:** Bajo a Alto (según privilegios del usuario)

### CONTENCIÓN

#### PASO 1: Invalidar Sesiones del Usuario (< 5 minutos)

bash

*# En WordPress (si aplica):*

```
mysql -u root -p wordpress -e "DELETE FROM wp_usermeta WHERE
meta_key='session_tokens' AND user_id=[USER_ID];"
```

*# En sistema Linux:*

*# Encontrar sesiones activas del usuario*

```
who | grep [username]
```

```
w | grep [username]
```

*# Terminar sesiones*

```
sudo pkill -9 -u [username]
```

*# Bloquear cuenta temporalmente*

```
sudo usermod -L [username]
```

#### PASO 2: Rotar Credenciales Inmediatamente

bash

*# Generar nueva contraseña segura*

```
NEW_PASS=$(openssl rand -base64 20)
```

*# Cambiar en sistema*

```
echo "[username]:$NEW_PASS" | sudo chpasswd
```

*# Cambiar en aplicaciones (WordPress, MySQL, etc.)*

*# Notificar al usuario por canal ALTERNATIVO (no email)*

*# (Llamada telefónica, SMS, Slack)*

### PASO 3: Revisar Actividad Reciente de la Cuenta

bash

*# Logins del usuario*

```
sudo grep "[username]" /var/log/auth.log | grep "Accepted"
sudo journalctl | grep "[username]" | grep "session opened"
```

*# Comandos ejecutados (si bash\_history está intacto)*

```
sudo cat /home/[username]/.bash_history | tail -100
```

*# Archivos accedidos/modificados*

```
sudo find /home/[username] -type f -mmin -60 -ls
```

### INVESTIGACIÓN

#### Determinar Si el Phishing Fue Exitoso:

##### Si fue Email de Phishing:

1. Obtener el email completo (con headers)
2. Analizar enlaces:

bash

*# Extraer URLs del email*

```
grep -oP 'https?://[^\s"<>]+' email.txt
```

*# Verificar en VirusTotal, URLhaus*

3. ¿El usuario hizo click? → Revisar logs de proxy/firewall
4. ¿El usuario introdujo credenciales? → Asumir comprometidas

##### Si fue Sitio de Phishing:

1. ¿Qué credenciales introdujo el usuario?
2. ¿Eran las mismas que usa en otros servicios? (Problema de reutilización)
3. Documentar el sitio malicioso (screenshot, URL) para reportar

### ERRADICACIÓN

1. **Cambiar credenciales en TODOS los servicios donde el usuario use la misma contraseña**
  - WordPress
  - Email corporativo
  - VPN
  - Herramientas cloud (Google Workspace, AWS, etc.)
2. **Implementar MFA para la cuenta afectada** (si no estaba activo)
3. **Revisar logs de todos los servicios usados por esa cuenta en las últimas 24-72h**

#### 4. **Buscar indicios de persistencia:**

- Claves SSH añadidas: `cat ~/.ssh/authorized_keys`
- Tokens de API generados
- Aplicaciones OAuth autorizadas (en servicios cloud)

### **RECUPERACIÓN**

1. Desbloquear cuenta solo tras verificar que está limpia
2. Obligar al usuario a cambiar contraseña en primer login
3. Monitoreo intensivo de la cuenta por 1 semana

### **PREVENCIÓN FUTURA**

#### **Para Este Usuario:**

- Formación individual en phishing
- Configurar MFA obligatorio
- Password manager corporativo

#### **Para Toda la Organización:**

- Campaña de concienciación sobre este phishing específico
- Actualizar filtros de email
- Bloquear dominio malicioso en firewall/DNS

## **7.4 PLAYBOOK PB-04: Exfiltración de Datos**

### **TRIGGERS:**

- Transferencias masivas de datos detectadas
- Acceso anómalo a bases de datos
- Usuario descarga gran volumen de archivos
- Alerta de DLP (Data Loss Prevention)

**SEVERIDAD:** Alto a Crítico

### **CONTENCIÓN INMEDIATA**

#### **PASO 1: Detener la Exfiltración Activa**

bash

*# Identificar el proceso que está enviando datos*

`sudo iftop -n -P`

`sudo nethogs`

*# Identificar el proceso*

`sudo lsof -i -P -n | grep ESTABLISHED | grep [IP_DESTINO]`



*# Terminar el proceso*

`sudo kill -9 [PID]`

*# Bloquear IP destino*

`sudo ufw deny out to [IP_DESTINO]`

## **PASO 2: Preservar Evidencia**

`bash`

*# Capturar tráfico de red (si aún está activo)*

`sudo tcpdump -i any -w /tmp/exfil_capture.pcap host [IP_DESTINO]`

*# Logs de conexiones*

`sudo ss -tunap > /tmp/connections_evidence.txt`

*# Archivos accedidos recientemente*

`sudo find / -type f -amin -60 > /tmp/recent_files.txt`

## **INVESTIGACIÓN**

### **Determinar Qué Se Exfiltró:**

#### **Si fue Base de Datos:**

`bash`

*# Logs de MySQL*

`sudo grep "SELECT|DUMP" /var/log/mysql/mysql.log`

*# Queries ejecutadas por usuario sospechoso*

`sudo mysql -u root -p -e "SELECT * FROM mysql.general_log WHERE user_host LIKE '%[USER]%' ORDER BY event_time DESC LIMIT 100;"`

*# Tablas accedidas*

#### **Si fueron Archivos:**

`bash`

*# Archivos accedidos por usuario*

`sudo find / -user [username] -type f -amin -120 -ls`

*# Logs de transferencias FTP (si aplica)*

`sudo grep [username] /var/log/vsftpd.log`

*# Logs de Apache (si fue vía HTTP)*

`sudo grep "GET|POST" /var/log/apache2/access.log | grep [IP_USUARIO]`

## Análisis de Tráfico de Red:

bash

# Si capturamos pcap

wireshark exfil\_capture.pcap

# Filtros útiles:

# - Buscar grandes volúmenes: Statistics > Conversations

# - Buscar transferencias de archivos: File > Export Objects > HTTP

## IMPACTO Y VALORACIÓN LEGAL

### Preguntas Críticas:

1. **¿Qué tipo de datos se exfiltraron?**
  - Datos personales (PII) → Notificación RGPD posible
  - Datos financieros → Auditoría interna, posible notificación
  - Propiedad intelectual → Evaluación legal
  - Datos públicos → Bajo impacto legal
2. **¿Cuántos registros?**
  - < 100: Posible notificación individual
  - 100-1000: Notificación AEPD probable
  - > 1000: Notificación AEPD obligatoria
3. **¿Quién exfiltró?**
  - Atacante externo → Incidente de seguridad
  - Empleado (accidental) → Incidente + RRHH
  - Empleado (malicioso) → Insider threat + Legal

## ERRADICACIÓN

1. Cerrar el vector de exfiltración:
  - Parchear vulnerabilidad si fue técnica
  - Revocar accesos si fue abuso de privilegios
  - Reforzar DLP para prevenir futuros
2. Rotar credenciales de sistemas afectados
3. Implementar monitoreo adicional en sistemas sensibles

## RECUPERACIÓN Y POST-INCIDENTE

### Acciones Legales/Regulatorias:

1. **Notificación AEPD (si aplica RGPD):**
  - Dentro de 72 horas desde conocimiento
  - Usar plantilla de sección 6.2
2. **Notificación a Afectados (si riesgo alto):**
  - Usar plantilla de sección 6.3
3. **Denuncia Policial:**
  - Si fue acto criminal (robo de datos, sabotaje)
  - Policía Nacional - Unidad de Delitos Telemáticos

### Mejoras de Seguridad:

- Implementar DLP robusto
- Clasificación de datos (público, interno, confidencial)
- Monitoreo de accesos a datos sensibles
- Formación en manejo de datos sensibles
- Revisión de privilegios de acceso (least privilege)

## 8. HERRAMIENTAS Y RECURSOS

### 8.1 Software de Respuesta a Incidentes

| Categoría           | Herramienta    | Propósito              | Licencia         |
|---------------------|----------------|------------------------|------------------|
| <b>SIEM</b>         | Splunk / ELK   | Correlación de logs    | Comercial / Open |
| <b>Ticketing</b>    | JIRA / TheHive | Gestión de incidentes  | Comercial / Open |
| <b>Forense</b>      | Autopsy        | Análisis de disco      | Open Source      |
| <b>Forense</b>      | Volatility     | Análisis de memoria    | Open Source      |
| <b>Malware</b>      | Cuckoo Sandbox | Análisis dinámico      | Open Source      |
| <b>Red</b>          | Wireshark      | Análisis de tráfico    | Open Source      |
| <b>Red</b>          | Zeek (Bro)     | IDS de red             | Open Source      |
| <b>Endpoint</b>     | OSQuery        | Monitoreo de endpoints | Open Source      |
| <b>Threat Intel</b> | MISP           | Compartir IoCs         | Open Source      |

### 8.2 Contactos de Emergencia

#### Internos:

| Rol            | Nombre   | Teléfono<br>24/7 | Email     |
|----------------|----------|------------------|-----------|
| Coordinador IR | [NOMBRE] | [+34 XXX]        | security@ |
| CIO            | [NOMBRE] | [+34 XXX]        | cio@      |
| CEO            | [NOMBRE] | [+34 XXX]        | ceo@      |
| Legal          | [NOMBRE] | [+34 XXX]        | legal@    |

## Externos:

| Entidad                 | Contacto                      | Teléfono    | Email/Web                                                                     |
|-------------------------|-------------------------------|-------------|-------------------------------------------------------------------------------|
| <b>Policía Nacional</b> | Unidad de Delitos Telemáticos | 091         | <a href="https://www.policia.es">https://www.policia.es</a>                   |
| <b>Guardia Civil</b>    | Grupo de Delitos Telemáticos  | 062         | <a href="https://www.gdt.guardiacivil.es">https://www.gdt.guardiacivil.es</a> |
| <b>AEPD</b>             | Notificaciones de Brechas     | 901 100 099 | notificaciones@aepd.es                                                        |
| <b>INCIBE-CERT</b>      | Alertas y Coordinación        | 017         | incibe@incibe.es                                                              |
| <b>Hosting Provider</b> | [Nombre] Soporte 24/7         | [+34 XXX]   | support@                                                                      |
| <b>ISP</b>              | [Proveedor] Incidentes        | [+34 XXX]   | abuse@                                                                        |
| <b>Ciber-Seguro</b>     | [Aseguradora] Emergencias     | [+34 XXX]   | claims@                                                                       |

## 8.3 Recursos de Threat Intelligence

### Feeds Públicos:

- AlienVault OTX: <https://otx.alienvault.com>
- Abuse.ch: <https://abuse.ch>
- MISP Communities: <https://www.misp-project.org>
- VirusTotal: <https://www.virustotal.com>
- URLhaus: <https://urlhaus.abuse.ch>
- MalwareBazaar: <https://bazaar.abuse.ch>

### Recursos de Descifrado de Ransomware:

- No More Ransom: <https://www.nomoreransom.org>
- ID Ransomware: <https://id-ransomware.malwarehunterteam.com>

### Bases de Datos de Vulnerabilidades:

- NVD (NIST): <https://nvd.nist.gov>
- CVE Details: <https://www.cvedetails.com>
- Exploit-DB: <https://www.exploit-db.com>

## 8.4 Formación y Certificaciones Recomendadas

### Para CSIRT:

- SANS SEC504 - Hacker Tools, Techniques, Exploits, and Incident Handling
- SANS FOR508 - Advanced Incident Response, Threat Hunting, and Digital Forensics
- GIAC GCIH - Certified Incident Handler
- GIAC GCFA - Certified Forensic Analyst

### Para Coordinador IR:

- CISSP - Certified Information Systems Security Professional
- CISM - Certified Information Security Manager

### Para Todos los Empleados:

- Formación anual de concienciación en seguridad
- Simulacros de phishing trimestrales

## 9. PLAN DE PRUEBAS Y EJERCICIOS

### 9.1 Programa de Ejercicios

**Objetivo:** Validar y mejorar continuamente las capacidades de respuesta a incidentes.

#### Ejercicios de Mesa (Tabletop Exercises)

**Frecuencia:** Trimestral

**Duración:** 2-4 horas

**Participantes:** CSIRT, IT, Management, Legal

#### Formato:

1. Presentación de escenario hipotético
2. Discusión de respuesta paso a paso
3. Identificación de gaps y mejoras
4. Documentación de lecciones aprendidas

#### Escenarios Rotativos:

- Q1: Ransomware
- Q2: Brecha de Datos / Exfiltración
- Q3: DDoS
- Q4: Insider Threat

## Simulacros Técnicos

**Frecuencia:** Semestral

**Duración:** 1-2 días

**Participantes:** CSIRT, IT

### Actividades:

- Simulación de compromiso real (con herramientas reales en entorno de test)
- Equipo debe detectar, responder, contener
- Cronometrado contra SLAs
- Métricas: MTTD, MTTR, efectividad de detección

## Red Team Exercises

**Frecuencia:** Anual

**Proveedor:** Externo especializado

**Alcance:** Full-scope (con exclusiones acordadas)

### Objetivos:

- Validar controles de detección
- Probar respuesta ante ataque real
- Identificar brechas de seguridad

## 9.2 Métricas de Ejercicios

| Métrica                           | Objetivo   | Medición                    |
|-----------------------------------|------------|-----------------------------|
| Tiempo de Detección en Ejercicio  | < 2 horas  | Cronómetro                  |
| Tiempo de Contención en Ejercicio | < 4 horas  | Cronómetro                  |
| % de Ataques Detectados           | > 90%      | Detecciones/Ataques totales |
| % de Participación en Tabletop    | 100% CSIRT | Asistencia                  |

## 9.3 Mejora Post-Ejercicio

Tras cada ejercicio:

1. Reunión de debrief (1-2 horas)
2. Documentar gaps identificados
3. Crear tickets de mejora con asignaciones
4. Revisión de progreso en próximo ejercicio

## **CONTROL DE DISTRIBUCIÓN**

Este documento es CONFIDENCIAL y solo debe ser distribuido a:

- Miembros del CSIRT
- Alta Dirección (CEO, CIO, CFO)
- Departamento Legal
- Personal de IT con necesidad de conocer